

ENTERPRISE INFORMATION SECURITY POLICY

Acceptable Use & Access Control

DOCUMENT CONTROL

Document ID: POL-GRC-2026-001

Version: 1.0

Classification: Internal / Confidential

Framework Alignment: ISO/IEC 27001:2022 Annex A.5, A.8 & NIST CSF (PR.AC)

Author: Fazilat bibi (Cybersecurity & GRC Analyst)

Review Date: July 2026

1. PURPOSE & OBJECTIVES

1.1 Purpose

The purpose of this Information Security Policy is to establish binding security standards for access control, asset protection, and information handling across the enterprise. This document defines acceptable operational boundaries to protect organizational assets, customer data, and infrastructure against unauthorized access, data leakage, and cyber threats.

1.2 Objectives

- To enforce robust identity and access management (IAM) mechanisms.
- To define clear guidelines for acceptable use of company IT resources.
- To comply with international regulatory standards (ISO/IEC 27001:2022).
- To mitigate operational risks associated with insider threats and phishing attacks.

2. SCOPE & APPLICABILITY

This policy applies to all full-time employees, visiting staff, third-party contractors, and external vendors who access organizational networks, databases, cloud resources, or physical assets.

3. ACCESS CONTROL & IDENTITY MANAGEMENT POLICY (ISO 27001 A.5.15 / A.8.5)

3.1 Least Privilege & Need-to-Know Basis

- **Role-Based Access Control (RBAC)** must be enforced across all systems. Users shall only be granted access privileges strictly required to perform their job duties.
- **Privileged access (Domain Admin, Root, Database Admin)** requires formal management approval and dual-custody authorization.

3.2 Password & Authentication Requirements

- **Password Complexity:** Minimum length of 12 characters, including uppercase, lowercase, numeric, and special symbols (@, #, \$, %, &).
- **Expiration & History:** Passwords must expire every 90 days. The last 5 passwords cannot be reused.
- **Multi-Factor Authentication (MFA):** MFA enforcement is **MANDATORY** for all remote VPN connections, administrative portals, and cloud environments.
- **Session Timeout:** Inactive user sessions must automatically lock after 10 minutes of inactivity.

4. ACCEPTABLE USE POLICY - AUP (ISO 27001 A.8.1 / A.8.7)

4.1 Asset Management & Encryption

- All corporate endpoints (laptops and workstations) must be protected using full-disk encryption (BitLocker / FileVault).
- Unauthorized removable media (USB flash drives, external HDDs) are disabled via Group Policy (GPO) to prevent Data Loss Prevention (DLP) breaches.

4.2 Internet & Email Conduct

- Corporate email addresses must not be used for personal accounts or unauthorized external registrations.
- Employees are prohibited from downloading or executing unapproved third-party software, executable files (.exe, .sh), or peer-to-peer (P2P) utility tools.
- All incoming and outgoing emails are subject to automated threat inspection for malicious attachments and phishing indicators.

5. INCIDENT MANAGEMENT & REPORTING (ISO 27001 A.5.24)

5.1 Reporting Escalation

Any suspected security breach, lost endpoint, credential compromise, or phishing attempt must be reported **IMMEDIATELY** (within 1 hour) to the Security Operations Center (SOC) / IT Security Team at: **security-incident@enterprise-domain.com**.

5.2 Non-Compliance & Disciplinary Action

Failure to adhere to this policy may lead to revocation of network access, formal disciplinary proceedings, or termination of employment in accordance with organizational regulations.

END OF DOCUMENT
